

# Okta user access review

|                |                                                   |
|----------------|---------------------------------------------------|
| Org            | https://acme-demo.okta.com                        |
| Data collected | 2026-09-15 14:00 UTC                              |
| Review date    | 2026-09-15                                        |
| Scope          | 11 users (10 not deprovisioned), 5 groups, 6 apps |
| HR roster      | demo_roster.csv, 9 people, SHA-256 b58126d195fd   |
| Status         | Complete                                          |
| Tool           | okta-access-review 0.1.0 (read-only)              |

## Summary

| Severity | CRITICAL | HIGH | MEDIUM | LOW | INFO | Total |
|----------|----------|------|--------|-----|------|-------|
| Findings | 5        | 4    | 5      | 1   | 2    | 17    |

## Findings

| Severity | Check                                         | Subject                            | Detail                                                                                                 |
|----------|-----------------------------------------------|------------------------------------|--------------------------------------------------------------------------------------------------------|
| CRITICAL | AR-01 Terminated in HR but account still live | marcus.lee@acme.example            | HR shows terminated on 2026-08-29; Okta status is ACTIVE.                                              |
| CRITICAL | AR-12 Leaver still holds a working credential | marcus.lee@acme.example            | Left 2026-08-29 but still holds API token ci-deploy.                                                   |
| CRITICAL | AR-12 Leaver still holds a working credential | victor.nguyen@acme.example         | Left 2026-07-15 but still holds API client they set up: Reporting Bot.                                 |
| CRITICAL | AR-13 Activity after the termination date     | marcus.lee@acme.example            | 2 sign-ins after 2026-08-29; last 2026-09-12 (Salesforce).                                             |
| CRITICAL | AR-13 Activity after the termination date     | victor.nguyen@acme.example         | 2 token grants after 2026-07-15 16:30 CDT; last 2026-09-14 (Reporting Bot).                            |
| HIGH     | AR-02 Contract or end date has passed         | sofia.ramos@acme.example           | End date 2026-06-30 has passed; Okta status is ACTIVE.                                                 |
| HIGH     | AR-03 Account has no HR record                | jordan.kim@acme.example            | No HR record for this ACTIVE account.                                                                  |
| HIGH     | AR-04 No MFA factor enrolled                  | lee.chen@acme.example              | Can sign in but has no MFA factor enrolled.                                                            |
| HIGH     | AR-10 API client with admin access            | Terraform Automation               | API client has admin roles: Super Administrator; write scope: okta.users.manage.                       |
| MEDIUM   | AR-05 Inactive account                        | hannah.ortiz@acme.example          | Last sign-in 2026-04-02 (166 days ago).                                                                |
| MEDIUM   | AR-06 Account never used                      | omar.haddad@acme.example           | Created 2026-07-01, status PROVISIONED, and has never signed in.                                       |
| MEDIUM   | AR-07 Contractor in employee-only group       | sofia.ramos@acme.example           | Contractor is a member of employee-only group 'Engineering'.                                           |
| MEDIUM   | AR-09 Disabled account still holds access     | victor.nguyen@acme.example         | Status DEPROVISIONED but still has groups: Finance; apps: Salesforce.                                  |
| MEDIUM   | AR-14 App assignment unused                   | lee.chen@acme.example / Salesforce | Assigned directly 2025-06-02; no sign-in since 2026-06-17.                                             |
| LOW      | AR-08 Missing manager or department           | grace.park@acme.example            | Profile is missing: manager, department.                                                               |
| INFO     | AR-11 Admin user                              | jordan.kim@acme.example            | Has admin roles: Help Desk Administrator. Confirm this is still needed.                                |
| INFO     | AR-11 Admin user                              | priya.shah@acme.example            | Has admin roles: Super Administrator; admin groups: Okta Administrators. Confirm this is still needed. |

## Remediation and control mapping

| Check                                         | Controls                                                     | Fix                                                                                                                    |
|-----------------------------------------------|--------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| AR-01 Terminated in HR but account still live | SOC 2 CC6.2, SOC 2 CC6.3, ISO 27001 A.5.18                   | Deactivate the Okta account and confirm app sessions are revoked.                                                      |
| AR-02 Contract or end date has passed         | SOC 2 CC6.2, ISO 27001 A.5.18                                | Deactivate the account or get the end date extended in HR.                                                             |
| AR-03 Account has no HR record                | SOC 2 CC6.2, ISO 27001 A.5.16                                | Identify the owner. Add to HR, list as a service account, or deactivate.                                               |
| AR-04 No MFA factor enrolled                  | SOC 2 CC6.1, ISO 27001 A.8.5                                 | Require MFA enrollment through an authentication policy.                                                               |
| AR-05 Inactive account                        | SOC 2 CC6.2, ISO 27001 A.5.18                                | Confirm with the manager whether access is still needed; suspend if not.                                               |
| AR-06 Account never used                      | SOC 2 CC6.2, ISO 27001 A.5.16                                | Confirm the account is still needed, or deactivate it.                                                                 |
| AR-07 Contractor in employee-only group       | SOC 2 CC6.3, ISO 27001 A.5.15                                | Remove the contractor from the group or document an approved exception.                                                |
| AR-08 Missing manager or department           | SOC 2 CC6.2, ISO 27001 A.5.16                                | Fill in the profile so the account has an accountable reviewer.                                                        |
| AR-09 Disabled account still holds access     | SOC 2 CC6.2, ISO 27001 A.5.18                                | Remove group memberships and app assignments so reactivation doesn't restore access.                                   |
| AR-10 API client with admin access            | SOC 2 CC6.3, ISO 27001 A.8.2                                 | Confirm each .manage scope and admin role is needed; prefer a least-privilege custom role.                             |
| AR-11 Admin user                              | SOC 2 CC6.3, ISO 27001 A.8.2                                 | Reviewer confirms each admin still needs the role.                                                                     |
| AR-12 Leaver still holds a working credential | SOC 2 CC6.2, SOC 2 CC6.3, ISO 27001 A.5.18                   | Revoke the API token and rotate or delete the client's credentials. Deactivating the account does not do either.       |
| AR-13 Activity after the termination date     | SOC 2 CC6.2, SOC 2 CC7.2, ISO 27001 A.5.18, ISO 27001 A.8.16 | Treat as a possible incident: revoke the credential, review what it reached, and confirm the termination date with HR. |
| AR-14 App assignment unused                   | SOC 2 CC6.2, ISO 27001 A.5.18                                | Remove the direct app assignment in Okta, or record why it is still needed.                                            |

## Access by user

Full detail, including apps, is in `access_matrix.csv`. Record decisions there.

| Login                     | Status      | Type     | Manager      | Last sign-in | MFA            | Admin roles             | Groups      |
|---------------------------|-------------|----------|--------------|--------------|----------------|-------------------------|-------------|
| grace.park@acme.example   | ACTIVE      | Employee |              | 2026-09-15   | push, webauthn |                         | Sales       |
| hannah.ortiz@acme.example | ACTIVE      | Employee | CFO          | 2026-04-02   | push           |                         | Finance     |
| jordan.kim@acme.example   | ACTIVE      | Employee | Grace Park   | 2026-09-12   | push           | Help Desk Administrator | Sales       |
| lee.chen@acme.example     | ACTIVE      | Employee | Priya Shah   | 2026-09-11   | none           |                         | Engineering |
| marcus.lee@acme.example   | ACTIVE      | Employee | Priya Shah   | 2026-08-28   | push           |                         | Engineering |
| nina.patel@acme.example   | SUSPENDED   | Employee | Grace Park   | 2026-05-30   | n/a            |                         |             |
| omar.haddad@acme.example  | PROVISIONED | Employee | Hannah Ortiz | never        | n/a            |                         | Finance     |
| priya.shah@acme.example   | ACTIVE      | Employee | CTO          | 2026-09-14   | push, webauthn | Super Administrator     | Engineering |

| Login                      | Status        | Type       | Manager      | Last sign-in | MFA                 | Admin roles | Groups      |
|----------------------------|---------------|------------|--------------|--------------|---------------------|-------------|-------------|
| sofia.ramos@acme.example   | ACTIVE        | Contractor | Priya Shah   | 2026-09-10   | sms                 |             | Engineering |
| svc-ci@acme.example        | ACTIVE        | Service    |              | 2026-09-15   | token:software:totp |             |             |
| victor.nguyen@acme.example | DEPROVISIONED | Employee   | Hannah Ortiz | 2026-07-14   | n/a                 | n/a         | Finance     |

Reviewer sign-off

I reviewed the findings and the access list above and recorded a decision for each user.

Reviewer name

Signature

Date